

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Week 3 Practical Laboratory

Roles, Responsibilities and Accountability in Security Governance

TechGlobal Governance Transformation Simulation

Student Name: Jackline Maina

Reg. No: C11/26/CGRCE/17588

Course: GRC102 – Information Security Governance

Module: Module 3 – Roles and Responsibilities in Security Governance

Date: 25/09/2026

Contents

Evidence Bundle 1: Governance Architecture & Stakeholder Analysis.....	4
1.1 Governance Gap Assessment	4
1.2 Stakeholder Map.....	5
1.3 Security Governance Organisation Chart	6
Consultant Justification	7
Evidence Bundle 2: Governance Responsibility Matrix.....	8
2.1 Cross-Functional Governance Responsibility Matrix.....	8
2.2 Role Profiles / Responsibility Cards	10
Board of Directors	10
Chief Executive Officer (CEO).....	11
Chief Information Security Officer (CISO)	12
Chief Risk Officer (CRO).....	13
Legal / Compliance	14
Finance	15
Human Resources (HR)	16
Information Technology (IT)	17
2.3 Conflict Resolution Note.....	18
Evidence Bundle 3: Governance Committee Ecosystem	19
Executive Security Council	19
Purpose	19
Members	19
Frequency	19
Security Governance Committee	20
Purpose	20
Membership	20
Frequency	20
Third-Party Risk Working Group.....	21

Purpose	21
Frequency	21
Membership	21
Sample Governance Committee Agenda.....	21
Sample Decision Log	22
12-Month Governance Calendar	22
Evidence Bundle 4: RACI Matrix.....	23
Evidence Bundle 5: Cyber-Risk Escalation Workflow	24
Escalation Thresholds	25
Evidence Bundle 6: Segregation of Duties Register.....	26
Decision Recording and Assurance Note	26
References.....	27

Evidence Bundle 1: Governance Architecture & Stakeholder Analysis

This section evaluates weaknesses in TechGlobal's current governance model and proposes an improved governance structure. The objective is to establish clear accountability, strengthen cyber-risk oversight, and ensure security responsibilities are distributed appropriately across the organisation.

1.1 Governance Gap Assessment

The existing governance structure is overly IT-centric and lacks independent oversight. This creates a risk that security decisions may prioritize operational convenience over enterprise risk management. For a 2,500-employee multinational technology organisation, security governance must be managed as an enterprise-wide business function rather than a purely technical responsibility.

Weakness	Consequence
IT Director acts as security owner, risk approver, and operational lead	Excessive concentration of authority and weak oversight
No formal governance committees	Security decisions lack transparency and accountability
Limited Board visibility of cyber risk	Material cyber risks may not receive strategic attention
Business units make independent security decisions	Inconsistent control implementation and increased risk exposure
No formal escalation process	Delayed response to significant cyber incidents

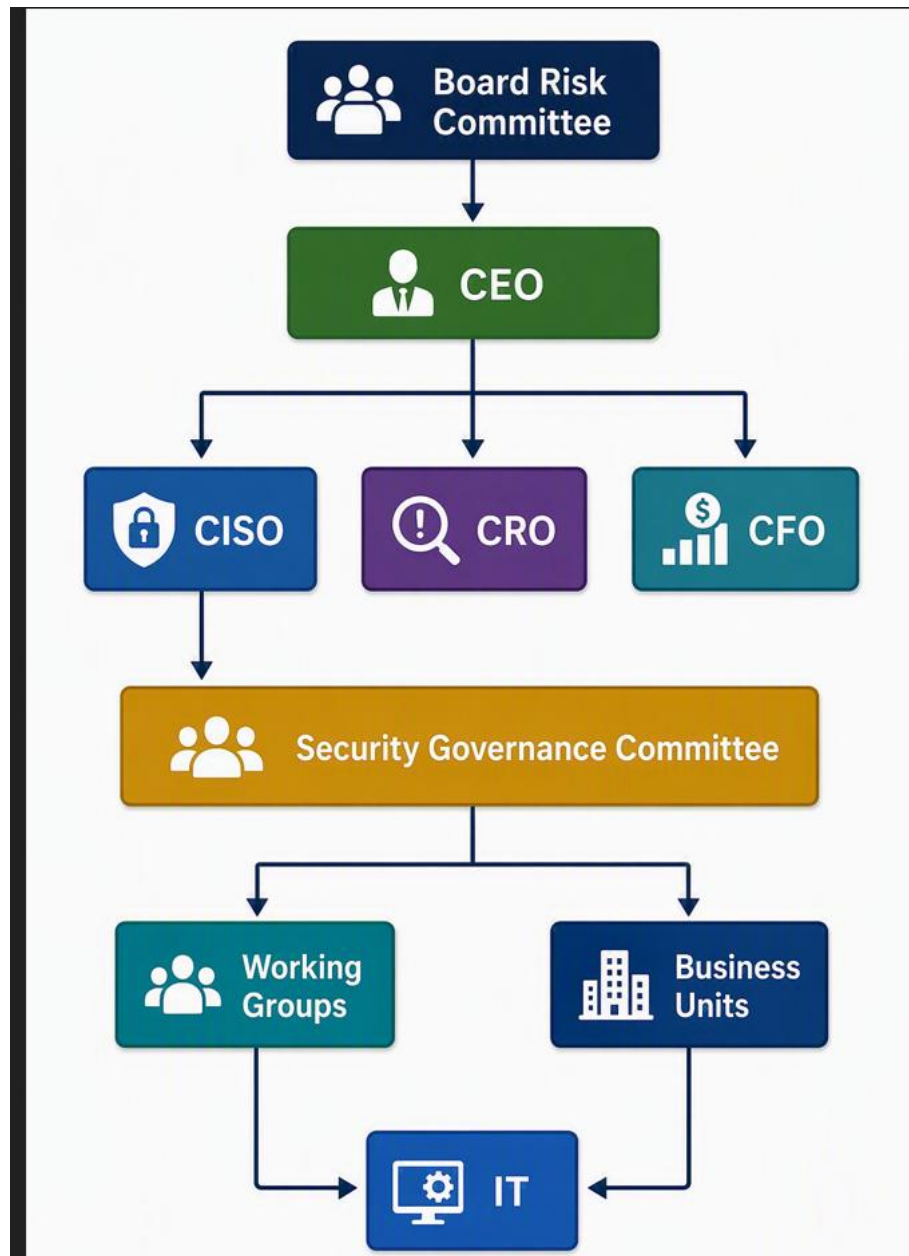
1.2 Stakeholder Map

Effective security governance requires active participation from multiple stakeholders. The stakeholder map identifies the authority, interests, information requirements, and governance responsibilities of key decision-makers involved in cybersecurity governance.

Stakeholder	Authority/ Influence	Primary Interest	Information Needed	Governance Contribution
Board	Highest	Risk appetite, compliance	Risk reports, assurance metrics	Oversight and strategic direction
CEO	Executive	Business objectives	Material cyber risks, budget needs	Executive sponsorship
CISO	Security leader	Security effectiveness	Threat intelligence, incidents	Security governance leadership
CRO	Enterprise risk	Risk treatment	Risk registers, KRIs	Risk integration
Legal	Regulatory	Compliance obligations	Incident notifications	Legal guidance
Finance	Financial governance	Cost control	Security business cases	Budget oversight
HR	Workforce governance	Security culture	Awareness metrics	Personnel controls
IT	Technology operations	System reliability	Security requirements	Technical implementation
Business Units	Operational ownership	Service delivery	Departmental risks	Control execution

1.3 Security Governance Organisation Chart

The following governance structure establishes clear reporting relationships and accountability pathways. It ensures strategic oversight at Board level while enabling effective operational execution and cross-functional decision-making across the organisation.



Consultant Justification

The proposed governance structure addresses TechGlobal's current dependence on informal, IT-driven security decision-making. It introduces clear accountability, independent oversight, and structured communication channels to ensure cybersecurity is managed as an enterprise risk rather than solely a technical issue.

The Board Risk Committee provides strategic oversight by setting risk appetite and reviewing material cyber risks, while the CEO ensures cybersecurity remains aligned with business objectives. This separation of oversight and execution strengthens governance and accountability.

The CISO leads the security programme, supported by the CRO and CFO to ensure security, risk, and financial considerations are balanced. This prevents excessive concentration of authority and promotes better decision-making.

The Security Governance Committee serves as the central forum for cross-functional collaboration, bringing together stakeholders from security, risk, legal, finance, HR, IT, and business units. This promotes consistent decision-making and ensures that security risks are evaluated from multiple perspectives.

Working Groups provide specialist expertise, while Business Units remain accountable for implementing controls within their operational areas. IT supports implementation and technical operations without holding sole governance authority.

Overall, the proposed structure provides clear roles, stronger oversight, improved risk visibility, and a scalable governance framework suitable for a 2,500-employee organisation operating across multiple locations.

Evidence Bundle 2: Governance Responsibility Matrix

Clearly defined responsibilities and decision rights are essential for effective governance. This section defines ownership, accountability, reporting relationships, and performance expectations for key governance stakeholders within TechGlobal.

2.1 Cross-Functional Governance Responsibility Matrix

The matrix below summarises the purpose, responsibilities, authority, reporting obligations, and key performance indicators associated with each governance role.

Role	Purpose	Core Responsibilities	Decision Authority	Reports / Escalates To	KPIs
Board	Provide strategic oversight of cyber risk	Approve security strategy, set risk appetite, review major incidents	Approve material risk acceptance	Shareholders	% strategic risks reviewed, frequency of cyber reporting
CEO	Executive accountability	Ensure security aligns with business objectives	Approve executive-level risk decisions	Board	Security strategy completion rate, risk treatment rate
CISO	Security governance leadership	Security strategy, policies, reporting, incident oversight	Security standards and control requirements	CEO/Board Committee	Incident SLA compliance, vulnerability remediation rate

Role	Purpose	Core Responsibilities	Decision Authority	Reports / Escalates To	KPIs
CRO	Enterprise risk integration	Risk management, risk assessment, risk reporting	Risk acceptance recommendations	CEO/Board	Risk treatment closure rate, risk register accuracy
Legal	Compliance oversight	Breach notification, legal advice, privacy compliance	Regulatory notification decisions	CEO	Regulatory compliance rate, legal deadlines met
Finance	Financial oversight	Security budgeting, financial risk monitoring	Budget approvals	CEO	Budget utilization, cost savings achieved
HR	Workforce governance	Awareness training, disciplinary processes	Personnel security decisions	CEO	Training completion rate, JML compliance rate
IT	Technical implementation	System security, patching, operations	Technical implementation decisions	CISO	Patch compliance, system availability

2.2 Role Profiles / Responsibility Cards

The following role profiles provide a detailed description of the purpose, responsibilities, authority, reporting obligations, and performance measures for each governance stakeholder.

Board of Directors

Purpose: Provide strategic oversight of cybersecurity risks.

Key Responsibilities

- Approve security strategy
- Define cyber-risk appetite
- Review significant incidents

Decision Authority

- Material risk acceptance
- Strategic cybersecurity investments

Reporting Obligations

- Receive quarterly cyber-risk reports

Performance Indicators

- Percentage of key cyber risks reviewed
- Number of Board cyber briefings conducted

Chief Executive Officer (CEO)

Purpose: Ensure cybersecurity supports business objectives.

Key Responsibilities

- Sponsor security initiatives
- Allocate resources
- Resolve governance conflicts

Decision Authority

- Executive risk decisions
- Security funding approval

Reporting Obligations

- Report organisational performance to the Board

Performance Indicators

- Completion of security initiatives
- Reduction in high-risk findings

Chief Information Security Officer (CISO)

Purpose

Lead the organisation's information security governance programme and ensure cyber risks are identified, managed, and communicated effectively.

Key Responsibilities

- Develop and maintain cybersecurity strategy.
- Establish security policies, standards, and procedures.
- Oversee incident response governance and security reporting.
- Monitor compliance with security requirements.

Decision Authority

- Approve security standards and control requirements.
- Recommend cyber-risk treatment and remediation actions.

Reporting Obligations

- Report security performance to the CEO.
- Provide regular cyber-risk updates to the Board Risk Committee.

Performance Indicators

- Incident response SLA compliance rate.
- Percentage of critical vulnerabilities remediated within target timelines.

Chief Risk Officer (CRO)

Purpose

Ensure cyber risks are managed within the enterprise risk management framework.

Key Responsibilities

- Maintain the cyber-risk register.
- Facilitate risk assessments and risk reviews.
- Monitor risk treatment plans.
- Escalate material risks to executive leadership.

Decision Authority

- Approve risk assessment methodologies.
- Recommend risk acceptance or treatment decisions.

Reporting Obligations

- Provide enterprise risk reports to executive leadership and the Board.

Performance Indicators

- Percentage of risks with current assessments.
- Risk treatment plan completion rate.

Legal / Compliance

Purpose

Provide legal, regulatory, privacy, and compliance oversight.

Key Responsibilities

- Advise on regulatory obligations.
- Support breach notification decisions.
- Review contracts and third-party agreements.
- Ensure compliance with privacy requirements.

Decision Authority

- Approve regulatory notification content.
- Provide legal guidance on compliance matters.

Reporting Obligations

- Escalate legal and regulatory issues to executive management.

Performance Indicators

- Regulatory compliance rate.
- Percentage of notifications submitted within required timelines.

Finance

Purpose

Provide financial governance and oversight of cybersecurity investments.

Key Responsibilities

- Review cybersecurity budgets.
- Monitor security-related financial risks.
- Evaluate return on security investments.
- Support business case development.

Decision Authority

- Approve cybersecurity budget allocations.
- Authorize major security expenditures.

Reporting Obligations

- Report budget performance to executive management.

Performance Indicators

- Security budget utilization rate.
- Percentage of approved security initiatives funded.

Human Resources (HR)

Purpose

Support workforce security governance and security culture.

Key Responsibilities

- Manage security awareness programmes.
- Oversee joiner, mover, and leaver processes.
- Coordinate disciplinary actions related to policy violations.
- Support insider-threat management activities.

Decision Authority

- Approve employee disciplinary actions.
- Approve security awareness training requirements.

Reporting Obligations

- Report training and policy compliance metrics.

Performance Indicators

- Security awareness completion rate.
- Joiner/Mover/Leaver compliance rate.

Information Technology (IT)

Purpose

Implement and operate secure technology solutions that support business operations.

Key Responsibilities

- Implement security controls and standards.
- Manage patching and vulnerability remediation.
- Maintain secure infrastructure and applications.
- Support incident response activities.

Decision Authority

- Approve technical implementation approaches.
- Manage operational technology changes.

Reporting Obligations

- Report operational security metrics to the CISO.

Performance Indicators

- Patch compliance rate.
- System availability and uptime percentage.

2.3 Conflict Resolution Note

In a cross-functional governance environment, certain responsibilities may overlap between stakeholders. The following examples identify potential conflicts and provide governance mechanisms for resolving them while maintaining accountability and segregation of duties.

Conflict	Issue	Risk	Resolution
CISO vs IT	IT operates security controls while the CISO oversees security governance.	IT may prioritize availability over security requirements.	The CISO sets security requirements while IT implements controls.
CRO vs CISO	Both roles influence cyber-risk decisions.	Confusion over final ownership of risk.	The CISO identifies and assesses cyber risks, while the CRO ensures alignment with enterprise risk processes.
Finance vs CISO	Security initiatives require funding approval.	Cost-saving decisions may delay essential security investments.	Security investments should be evaluated through the Security Governance Committee using risk-based business cases.

Governance Principles for Resolving Authority Conflicts

- ✓ Clear separation of governance and operational responsibilities.
- ✓ One accountable owner for every major decision.
- ✓ Escalation to the CEO for unresolved conflicts.
- ✓ Material cyber-risk decisions escalated to the Board Risk Committee.
- ✓ All decisions documented in the Governance Decision Register.

Evidence Bundle 3: Governance Committee Ecosystem

Governance committees provide structured forums for collaboration, decision-making, risk management, and oversight. The proposed committee ecosystem ensures that cybersecurity decisions are reviewed from multiple business perspectives and escalated appropriately when required.

Executive Security Council

The Executive Security Council provides senior leadership oversight of cybersecurity strategy, risk, investment priorities, and organisational security performance.

Purpose

Provide executive-level security oversight.

Members

- CEO (Chair)
- CISO
- CRO
- CFO
- HR Director
- General Counsel

Frequency

Quarterly

Security Governance Committee

The Security Governance Committee serves as the central decision-making body for cybersecurity governance matters and ensures coordination across business functions.

Purpose

Coordinate enterprise-wide security decisions.

Membership

- CISO (Chair)
- Risk Manager
- IT Manager
- Legal Representative
- HR Representative
- Business Unit Representatives

Frequency

Monthly

Third-Party Risk Working Group

The Third-Party Risk Working Group focuses on identifying, assessing, and managing security risks associated with vendors, suppliers, and other external service providers.

Purpose

Manage supplier and vendor security risks.

Frequency

Monthly

Membership

- Procurement
- Legal
- CISO Office
- Risk Team

Sample Governance Committee Agenda

The following agenda demonstrates how governance meetings can be structured to support effective oversight and decision-making.

1. Previous actions review
2. Incident metrics
3. Emerging threats
4. Policy approvals
5. Third-party risks
6. Risk acceptance requests
7. Audit findings
8. Action tracking

Sample Decision Log

A decision log provides an auditable record of governance decisions, approvals, actions, and accountability assignments.

Date	Issue	Owner	Decision
01-Oct-2026	MFA rollout	CISO	Approved
05-Oct-2026	Vendor assessment requirement	CRO	Approved
10-Oct-2026	Cloud security funding	CFO	Approved

12-Month Governance Calendar

The governance calendar outlines recurring activities designed to maintain effective oversight, continuous improvement, and regulatory compliance throughout the year.

Month	Governance Activity
January	Annual risk assessment
February	Policy review
March	Board cyber briefing
April	Incident exercise
May	Third-party review
June	Mid-year risk review
July	Awareness campaign
August	DR exercise
September	Budget planning
October	Audit review
November	Governance maturity assessment
December	Annual Board report

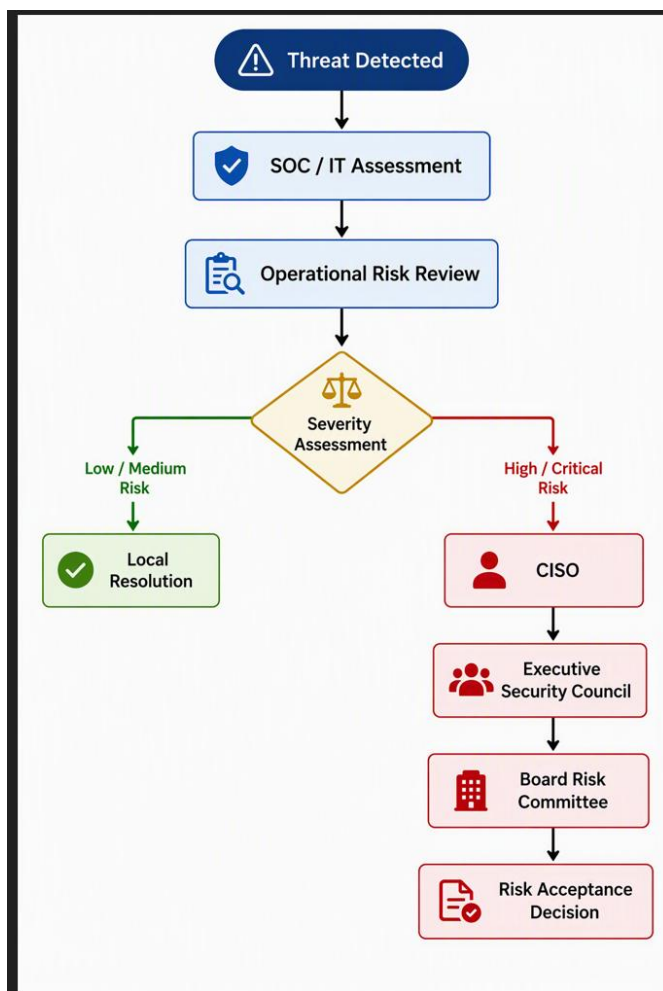
Evidence Bundle 4: RACI Matrix

The RACI matrix clarifies roles and responsibilities for critical cybersecurity governance activities. It identifies who is Responsible (R), Accountable (A), Consulted (C), and Informed (I) for each activity, reducing ambiguity and improving accountability.

Activity	Board	CEO	CISO	CRO	Legal	Finance	HR	IT	BU
Cybersecurity Strategy	A	C	R	C	I	C	I	C	I
Security Policy Approval	A	C	R	C	C	I	C	I	I
Enterprise Risk Assessment	I	I	R	A	C	I	I	C	C
Risk Acceptance	A	R	C	C	I	I	I	I	I
Security Budget	C	A	R	I	I	R	I	I	I
Architecture Approval	I	I	A	I	I	I	I	R	I
Third-Party Review	I	I	A	R	C	I	I	I	C
Access Governance	I	I	A	I	I	I	C	R	I
Incident Governance	I	C	A	C	C	I	I	R	I
Material Escalation	I	A	R	C	C	I	I	I	I
Regulatory Notification	I	A	C	I	R	I	I	I	I
Security Awareness	I	I	A	I	I	I	R	C	I
Vulnerability Oversight	I	I	A	I	I	I	I	R	I
Business Continuity	I	A	C	R	I	I	I	C	C
Board Reporting	A	C	R	C	I	I	I	I	I

Evidence Bundle 5: Cyber-Risk Escalation Workflow

A formal escalation process ensures that significant cyber risks receive the appropriate level of management attention. The workflow below illustrates how cyber-risk issues move from operational detection through executive review and Board oversight.



Escalation Thresholds

The table below defines the thresholds, decision authorities, and response expectations associated with each escalation level.

Level	Trigger	Authority	Response Time
Level 1 Operational	Localised incident	IT Manager	24 hours
Level 2 Executive	High severity incident	CISO/CEO	4 hours
Level 3 Board	Material financial or regulatory impact	Board	Immediate

Evidence Bundle 6: Segregation of Duties Register

Segregation of duties is a key governance principle that prevents conflicts of interest and reduces the risk of inappropriate decision-making. The register below identifies weaknesses within TechGlobal's current model and proposes practical controls to mitigate associated risks.

ID	Weakness	Risk	Recommended Control
1	IT approves and implements access	Fraud risk	Independent access review
2	IT accepts cyber risk	Lack of oversight	CRO approval required
3	CISO manages audit findings and closes them independently	Concealment risk	Internal Audit verification
4	Developers deploy directly to production	Change risk	Change Advisory Board
5	Vendor onboarding without security review	Supply chain exposure	Mandatory security assessment

Decision Recording and Assurance Note

To maintain accountability and provide evidence of governance decisions, TechGlobal should maintain a formal decision register. This ensures that key decisions, approvals, and risk acceptance activities are properly documented, reviewed, and auditable over time.

All significant governance decisions should be documented in a centralized Governance Decision Register containing:

- Decision date
- Decision owner
- Risk assessment
- Supporting evidence
- Approval authority
- Action owner
- Target completion date
- Review date

The Security Governance Committee should review the register monthly, while the Board Risk Committee reviews material decisions quarterly. This provides traceability, accountability, and an auditable governance trail.

References

- ISACA. (2019). *COBIT 2019 Framework: Governance and Management Objectives*.
- ISO/IEC. (2022). *ISO/IEC 27001:2022 Information Security Management Systems*.
- ISO/IEC. (2022). *ISO/IEC 27014: Governance of Information Security*.
- National Institute of Standards and Technology (NIST). (2024). *Cybersecurity Framework (CSF) 2.0*.
- National Institute of Standards and Technology (NIST). (2012). *NIST SP 800-61 Rev. 2: Computer Security Incident Handling Guide*.